

REAL 智能体统一风险矩阵 与自动化红队实践

当 AI Agent 出了事，怎么分类、怎么测、怎么治

演讲人：阿里 AI 红队负责人 - 宋奇钊(胖鲮)

阿里 AI 红队：智能体安全前沿风险研究

阿里巴巴人工智能治理与可持续发展研究中心（AAIG）是阿里巴巴集团旗下AI顶级研发团队，致力于利用AI技术解决安全风险问题。团队在顶级会议和期刊发表论文100+篇，专利授权60余项。产品涵盖内容安全、业务风控、网络安全、数据安全与算法安全等多个领域，为全球千万商家和十亿消费者提供安全保障。

AI红队是AAIG专攻AI安全攻防的核心团队，国内最早系统性开展智能体安全研究的组织之一。团队在主流AI产品中持续发现重大安全漏洞，成果发表于多个权威安全与AI顶会，并深度参与国家AI安全标准制定与监管合作。当前聚焦前沿AI安全研究，攻坚覆盖云端Agent、端侧Agent、AI眼镜及智能硬件等全形态智能体攻击面挖掘与纵深防御。

100+

顶会论文

安全与 AI 领域权威会议

60+

专利授权

攻防技术 · 检测方法 · 安全架构

深度参与

国家 AI 安全标准

GB/T 系列 · TC260 · 治理框架 2.0

4 大载体

全形态攻击面覆盖

Cloud · Mobile · Desktop · Hardware

在多个主流 AI 产品中持续发现高危漏洞，覆盖从模型训练到推理服务到用户侧 Agent 的全链路

Token 制造 → 运输 → 消费，每一层都被打穿



⚡ **Agent 能力有多强，攻击面就有多大** — 从模型训练到用户侧 Agent，全链路已实证覆盖

目录

01

为什么需要体系化

现有方法局限 · 统计数据 · 紧迫性

02

REAL Matrix 三维坐标系

RxE@L · 16 格 · Agent≠Chatbot

03

实战分析

同一坐标两种形状 · 横向扩散 · 纵向穿透

04

从矩阵到自动化红队

以 Agent 测 Agent · 安全水位度量

05

发展曲线与展望

挡→围→盯 · 趋势信号

01

为什么需要体系化

行业不缺风险清单，缺的是能分类、能测、能治的统一坐标系

收集49 产品的133 条 漏洞， 风险极具增长

Agent 生态漏洞数据全景扫描

高危密度异常



85%

Critical + High 合计 85%
远高于传统软件生态

严重程度集中在高危以上

利用窗口坍缩



月→时

发现漏洞→写出利用
从数月压缩到数小时

AI 加速攻击武器化

根因高度集中



87%

注入 + 基建缺陷占 87%
同一根因，治法完全不同

形状不同，不能一刀切

⚡ 结论

风险既杂（形状不同 / 跨层传播 / 非对抗也致害）又快（利用窗口坍缩 / 规模化扫荡）—— 需要统一坐标系，而不是更长的清单

行业不缺风险清单，缺的是能分类、能测、能治的统一坐标系

OWASP LLM Top 10 → REAL 三维定位 → 重新标注

OWASP LLM Top 10 (原始)

1. Prompt Injection 提示词注入
2. Sensitive Information Disclosure 敏感信息泄露
3. Supply Chain 供应链
4. Data & Model Poisoning 数据/模型投毒
5. Improper Output Handling 输出处理不当
6. Excessive Agency 过度代理
7. System Prompt Leakage 系统提示泄露
8. Vector & Embedding 向量/嵌入弱点
9. Misinformation 错误信息
10. Unbounded Consumption 无限消耗

攻击手段与后果混在同一层级

缺「层级」维度，无法定位攻击发生在哪

REAL 三维坐标系

R 为什么出事? Root Cause
R1 指令注入 Injection
R2 幻觉偏差 Hallucination
R3 基建缺陷 Infrastructure
R4 功能滥用 Abuse

E 出了什么事? Effect
C 机密性 Confidentiality
I 完整性 Integrity
A 可用性 Availability
S 无害性 Safety

L 在哪层出事? Layer
L1 交互层 — 输入解析·身份认证·输出过滤
L2 认知层 — RAG检索·长期记忆·推理引擎
L3 执行层 — 工具调用·系统操作·多智能体编排
L0 基建层 — 沙箱/容器·网络通信·数据存储·依赖

用决策树试标

✅ 原因型——可定位 R

- | | | |
|-----------|----|-------|
| 1. 提示词注入 | R1 | L1/L2 |
| 5. 输出处理不当 | R3 | L1 |
| 9. 错误信息 | R2 | L2 |

⚠️ 后果型——只描述 E，缺 R

- | | |
|-----------|-------|
| 2. 敏感信息泄露 | E=C |
| 6. 过度代理 | E=I/A |
| 10. 无限消耗 | E=A |

❓ 无法区分——原因/手段/后果混合

- | | |
|------------|----------|
| 3. 供应链 | 攻击面? 原因? |
| 4. 数据/模型投毒 | 手段? 原因? |
| 7. 系统提示泄露 | 后果? 原因? |
| 8. 向量/嵌入弱点 | 攻击面? 原因? |

只有 3/10 能清晰定位根因 — 扁平清单的分类维度本身就有问题，需要多维坐标系

例：Meta 总监的 Agent 无视停止指令，自主清空数百封邮件 OWASP: #6过度代理? #9错误信息? ——模糊 REAL: R2.2认知误判 × A可用性 @L2认知→L3执行 ——模型判断错 + 动作穿层，一目了然

REAL-智能体风险导航坐标

经纬度只有两个数字
却能定位地球上任何一个点

我们需要类似的东西——把千变万化的 Agent 风险，锁定到三个维度：

为什么出事（根因）× 出了什么事（影响）× 在哪出事（层级）

维度固定，攻击形态再怎么变，坐标系不用改；格子空着的地方，就是下一个要打的靶

02

REAL Matrix 三维坐标系

$R \times E @ L$ —— 一个坐标系，回答根因 / 影响 / 位置



一张图看懂 AI 智能体风险

REAL Matrix: 用原因 × 后果 × 位置统一描述风险

$$REAL = R(\text{原因}) \times E(\text{后果}) @ L(\text{位置})$$

看到一个 AI 风险时，只要回答 3 个问题：为什么出事？出了什么事？出事在哪一层？

框架有什么用

给漏洞贴统一标签

给风险排优先级

对齐测试与监管

适用对象：红队、产品、
合规、监管、管理层

典型风险示例

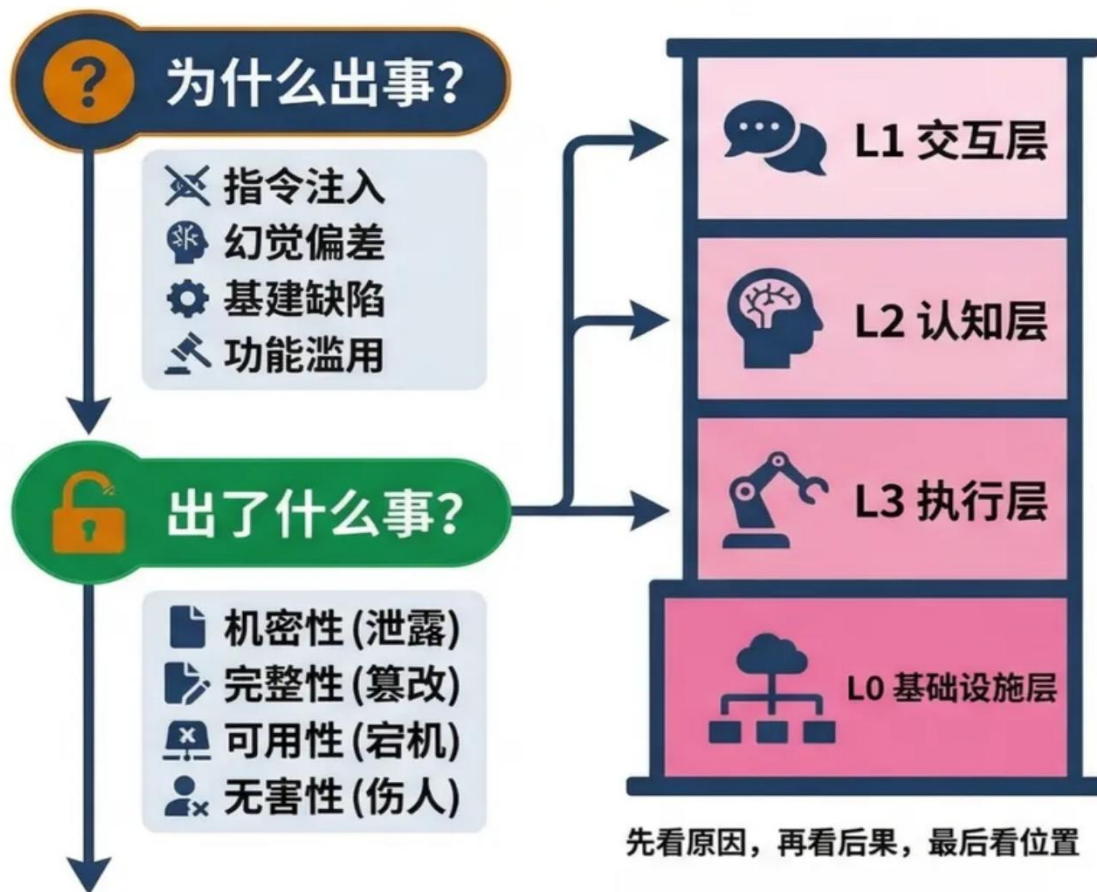
恶意网页把 Agent 带偏 →
读走敏感信息 @ L1/L2 (R1, E2)

模型自己胡编乱造 →
做出错误决策 @ L2 (R2, E3)

恶意插件或依赖有后门 →
篡改系统或取密钥 @ L3/L0 (R3, E1)

正常自动化能力被拿去群发诈骗 →
伤害外部用户 @ L3 (R4, E4)

3 个问题定位风险



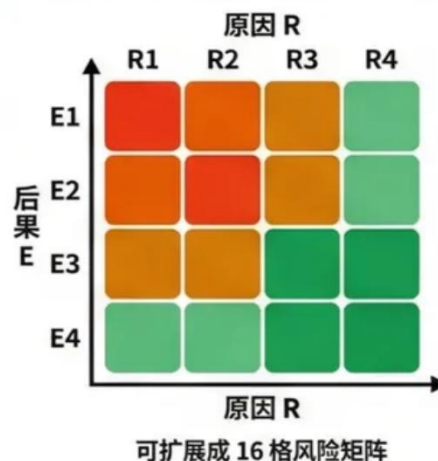
术语翻译

? R = 原因

🔒 E = 后果

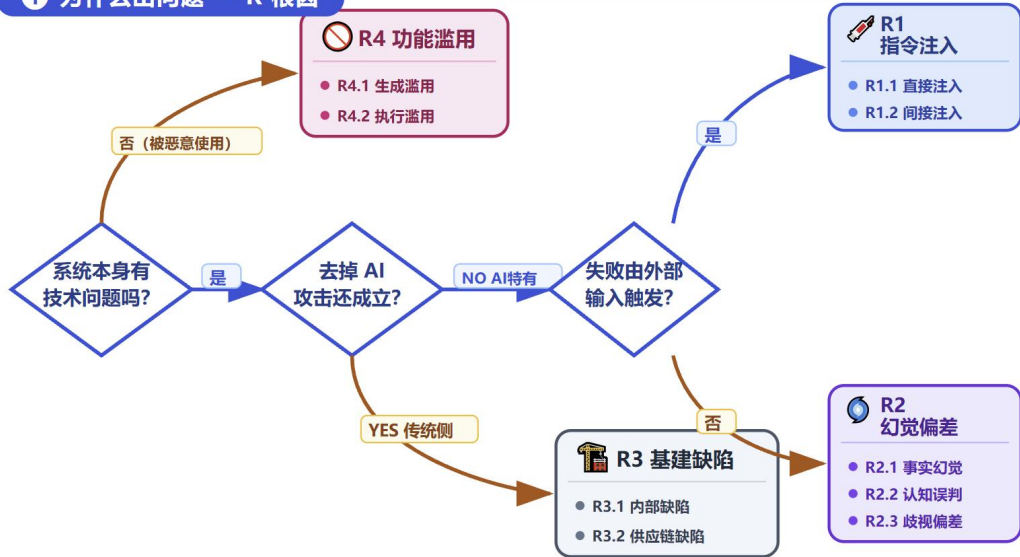
🏠 L = 位置

🏆 P0 = 最优先处理

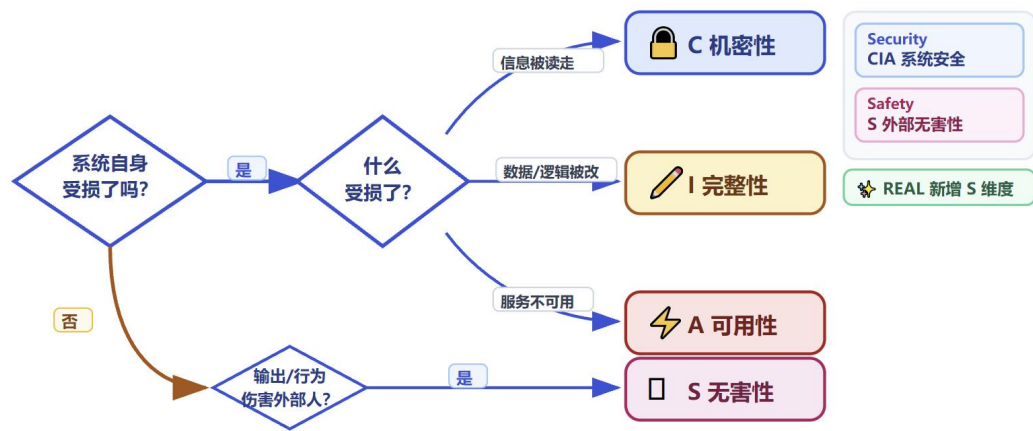


因为什么(R) 造成 什么影响(E) @ 发生哪里(L) ?

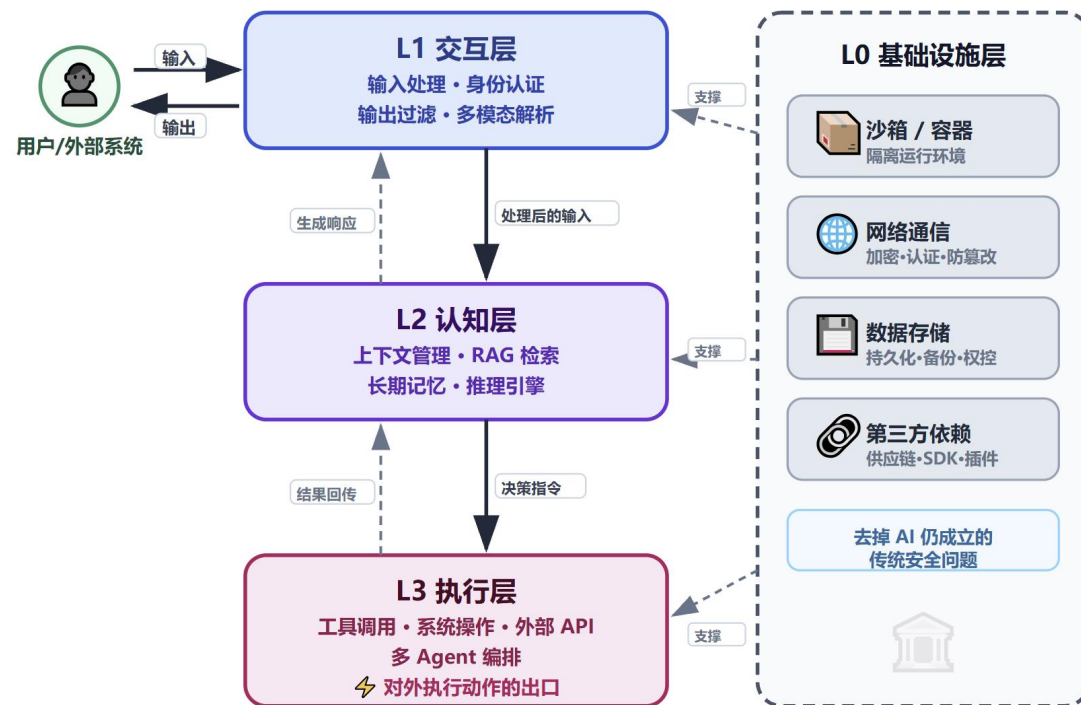
① 为什么出问题 → R 根因



② 出了什么问题 → E 影响



③ 在哪里出问题 → L 层级



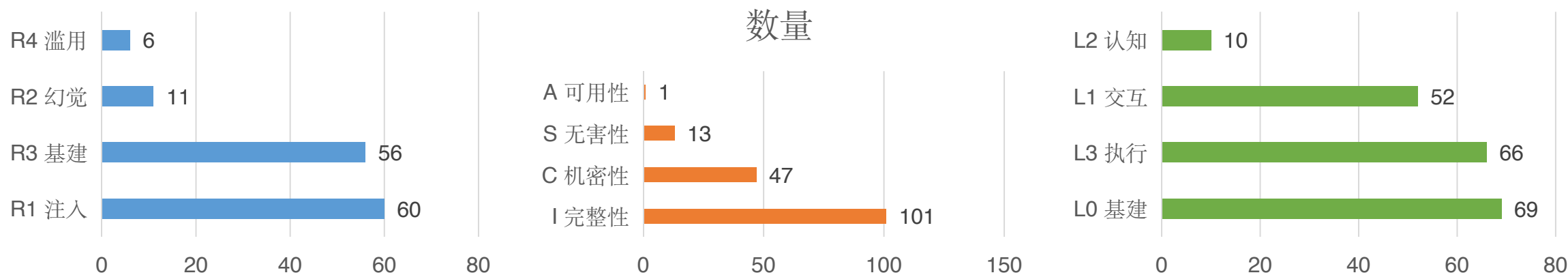
⚠ 跨层攻击链示例 (间接注入 → 意图劫持 → 恶意执行)



坐标: R1.2×C @L1→L2→L3 | 每一步单独看都是“合法操作”, 传统过滤无法检出

回头看133 条公开漏洞在REAL矩阵中的分布

数据来源: 2024-2026 公开披露 (CVE / GHSA / Bug Bounty / 学术 / 厂商公告)



核心发现

R1 注入 + R3 基建 = **87%**, 两大主风险面; R1.2 间接注入 (35 条) 最高频

I 完整性 **62%** 说明攻击者追求的是代码执行 / 控制权

L0 + L3 = **69%**: 主战场在运行环境与工具调用两端

基于外部漏洞与内部实战: 风险分布是高度一致的

R \ E	C 机密性	I 完整性	A 可用性	S 无害性
R1 注入	★ 注入诱导Agent吐出凭据	★ 注入劫持Agent篡改配置	注入payload触发死循环	越狱生成CBRN/自伤教程
R2 认知	幻觉虚构依赖包名致凭据被窃	幻觉虚构参数致Agent写坏数据	★ 偏差致Agent误删关键文件	偏差致系统性打低分
R3 基建	★ API未鉴权致凭证批量暴露	★ Gateway未授权/RCE致系统被控	中间件漏洞致拒绝服务	机器人接口无认证致远程操控
R4 滥用 △	★ 员工指令Agent总结文档外发	用户指令Agent批量删数据	刷量占满API额度致停摆	滥用Agent群发诈骗

★ = 实测高频高危; △R4 = 系统无缺陷, 治理层问题



那这个坐标系有了, 我们又能做什么呢?

从 漏洞标签 到 实战轨迹标记

03

实战分析

一条链打穿一个系统,一条链感染数千人

纵向穿透：四道防线，从顶到底被打穿

R1 注入@L1 ↓ R1 注入@L2 ↓ R3.1 缺陷@L3 ↓ R3.1 缺陷@L0

提示词护栏 → 内生对齐 → 元数据隔离 → 凭证权限 — 没有任何一层拦住 · 横轴=攻击步骤 纵轴=REAL L层级(穿透深度)



攻击步骤 → 逐层突破 · 根因从 R1 注入切换到 R3 基建缺陷 · 同一组织内三个团队各管一段

Cline 供应链攻击：一个标题注入，横穿多个层面

R1.2 间接注入



R3.1 内部缺陷

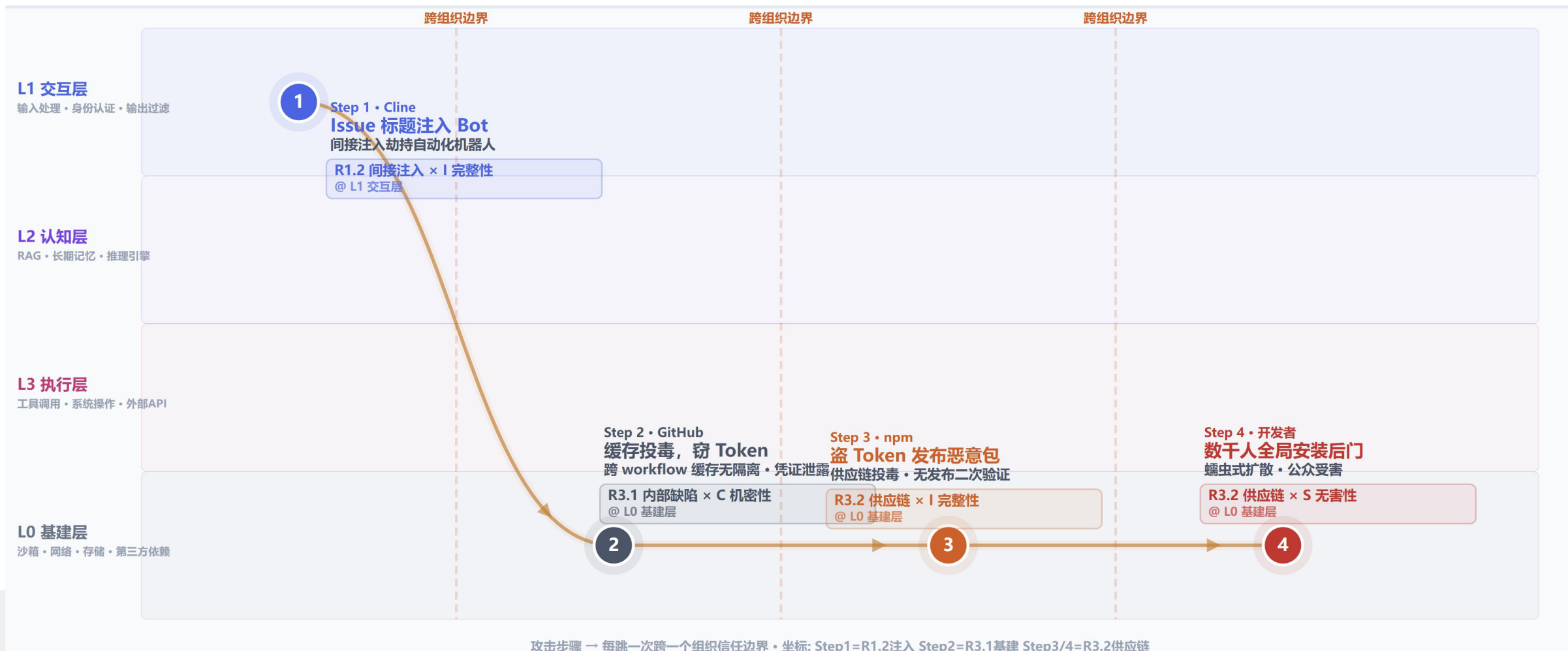


R3.2 供应链



R3.2 供应链

每跳一次跨一个组织的信任边界 · 每一步内部都有独立可修复的缺陷 · 横轴=攻击步骤(跨组织) 纵轴=REAL L层级



形状完全不同，同一套坐标标得清清楚楚

纵向穿透 一句话接管云

一个系统从顶到底被打穿 · 跨两种根因 (R1 注入 + R3 基建)

L1 交互层

注入绕过提示词护栏

用户输入 → 恶意指令穿透

$R1 \times I @ L1$

▼ 突破

L2 认知层

内生对齐被突破

模型遵循恶意指令

$R1 \times I @ L2$

▼ 劫持

L3 执行层

读取元数据获取凭证

工具调用越权 → 窃取云凭证

$R3.1 \times C @ L3$

▼ 窃取

L0 基建层

接管云主账号

基础设施全面失陷

$R3.1 \times I @ L0$

同一组织内三个团队各管一段 → 坐标系让每方知道修什么

横向扩散 Cline 供应链攻击

一个人的失陷扩散到数千人 · 跨三种根因 (R1.2 + R3.1 + R3.2)

Step 1 · Cline

Issue 标题注入 Bot

间接注入劫持自动化机器人

$R1.2 \times I @ L1$

Cline

↘ 跨组织

Step 2 · GitHub

缓存投毒，窃 Token

跨 workflow 缓存无隔离

$R3.1 \times C @ L0$

GitHub

↘ 跨组织

Step 3 · npm

盗 Token 发布恶意包

供应链投毒 · 无二次验证

$R3.2 \times I @ L3$

npm

↘ 扩散

Step 4 · 开发者

数千人全局安装后门

蠕虫式扩散 · 公众受害

$R3.2 \times S @ L0$

开发者

四个组织各执一词 → 同一套坐标系让每方知道自己修什么

矩阵证明了三件事：

- ① 纵向穿透与横向扩散，同一套坐标即可标注
- ② 跨组织归因、跨团队协作，都走同一坐标系
- ③ 坐标轨迹直接指向该加固的位置

不同的案例，同一套坐标系

①	Claude Code 命令注入窃 SSH 私钥 echo 免审批 + \$() 替换 → 零交互窃取凭证	CVE-2025-54795	R1.2×C@L3
②	豆包编造退票规则致用户损失 600 元 凭空编造“手续费仅5%” → 用户信赖操作 → 起诉	北京互联网法院	R2.1×S@L2
③	OpenClaw 面板裸奔泄 1.8 亿 Token 反代误配 → 管理面板公网无认证 → API Key + 聊天全泄	vuldb 公开披露	R3.1×C@L0
④	深伪央视主持人推销假药 AI 换脸+语音合成 → 直播间虚假带货 → 全国首案	海淀市场监管局	R4.1×S@L3

R×E 智能体风险矩阵 · 点亮覆盖

	C 机密	I 完整	A 可用	S 无害
R1 注入	① 注入→ 凭证窃取			
R2 幻觉				② 幻觉→ 用户受损
R3 基建	③ 缺陷→ 凭证泄露			
R4 滥用				④ 滥用→ 公众欺骗

每个 R 恰好一个案例 · 四格对角线点亮

+ 前页 Cline 深拆横跨 R1→R3 再补 3 格

一案一根因：R1 注入① · R2 幻觉② · R3 基建③ · R4 滥用④ | 来源均可公开验证：CVE · 法院判决 · vuldb · 监管执法



一条链靠专家手打 + 标坐标都不轻松 10+ 条产品线、每格都要覆盖，怎么办？

把「云接管」「Cline 供应链」这些实战经验沉淀为按坐标组织的测试用例库，
让 Agent 自动跑——从按坐标打靶走向规模化自动红队

04

从矩阵到自动化红队

以 Agent 测 Agent · 安全水位度量

困境：一个产品，一个专家

产品线越多，人力越紧张；专家的攻击经验沉淀在个人脑子里，无法复用、无法规模化

人力不可扩展

产品线 N 倍增长，红队专家无法 N 倍复制

新产品上线即出现覆盖盲区

经验难复用

一条高价值攻击链，换个产品或过段时间即沉没

无法自动回归验证是否复发

速度追不上

利用窗口已坍缩到数小时

人工逐个产品打靶天然慢于攻击者

出路：把专家攻击经验编码进矩阵，再让 Agent 自动化执行——

矩阵 → 用例库 → 以 Agent 测 Agent → 安全水位度量 → 态势感知

把 REAL 矩阵变成可规模化执行的流水线



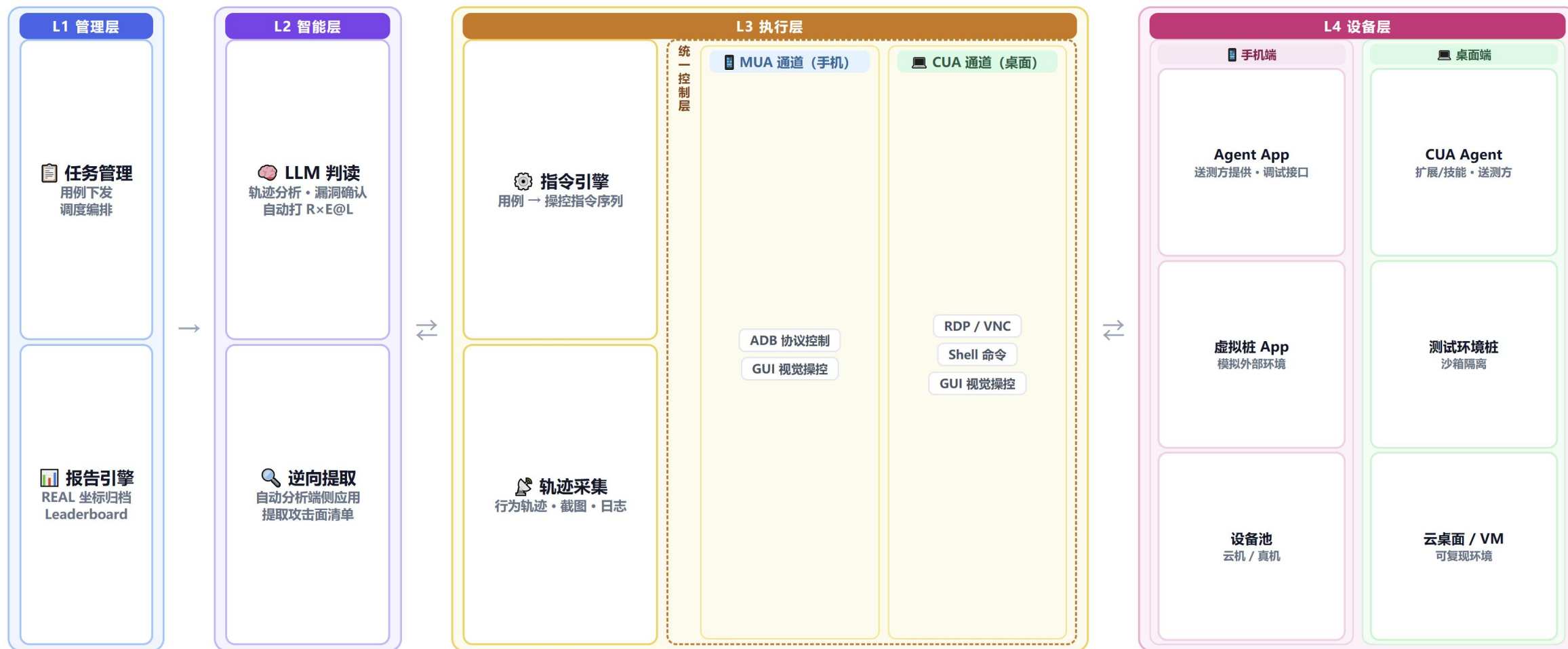
↻ **新手法回流**: 被测结果中发现的新攻击模式, 自动沉淀回「用例库」, 扩充覆盖

↻ **专家编码**: 专家红队探索前沿 → 新手法编码为可执行用例 → 进入库自动回归

环形回路: 专家发现 → 编码 → 自动批量执行 → 回归覆盖「已知风险」 → 新风险再沉淀回库

以 Agent 测 Agent: 自动化评测架构

REAL 矩阵驱动 · 覆盖 Mobile / CUA 桌面 / Web 三类智能体



● REAL 矩阵 → 用例库 → 指令引擎 ● 控制层操控设备 → 轨迹回传 ● LLM 判读 → R×E@L 归因 → 报告 ● 新手法回流用例库 · 闭环迭代



以桌面助手类为例：多维度洞察智能体风险

桌面助手评测

查看评测报告 →

★ 评测核心洞察



维度一 · 响应随机性

模型响应存在显著随机性

≈26%

同一 Agent、同一模型两次独立运行的判定结果存在约 26% 的翻转比例，单次测试结果具有固有不确定性。



维度二 · AGENT 框架

Agent 框架提供额外安全增强

+16.0%

相同模型(Qwen3.6)下， ASR 为 7.8%， ASR 为 23.8%，框架贡献约 16.0 个百分点。



维度三 · 模型版本

模型能力是安全防御决定性因素

≈56%

相同 Agent( )下，从标准版切换到 Qwen3.6，ASR 从 79.7% 降至 23.8%，模型贡献高达约 56 个百分点。



维度四 · 直接 VS 间接注入

多轮持续社工同样是重大威胁

20-40轮

攻击面不仅是单次注入 (L3)；当攻击者通过 20-40 轮对话逐步引导时防线更易被突破，防御需具备跨轮次意图追踪能力。

模型贡献 · ≈56pp 框架贡献 · +16.0pp 随机性翻转 · ≈26% 样本规模 ·  条

桌面助手间接注入ASR ASR 越低防御越强

AGENT 框架	模型版本	总体成功率	多次复测值	随机性
  	 Qwen3.6	7.8%	21.6%	≈26%
 	 Qwen3.6	23.8%	—	≈26%
 	 高级版	31%	—	—
 	 标准版 (基线)	79.7%	—	—



今日之观测，明日之路又在何方？

立足当前，遥望未来的Agent安全

极客邦科技 2026 年会议规划

促进软件开发及相关领域知识与创新的传播



参会咨询

🕒 8月 📍 深圳 🧑 1000人

AiCon

全球人工智能开发与应用大会

会议时间：8月21-22日

- Agentic AI
- 轻量化与高效推理
- 多模态应用
- AI + IoT 场景实践
- AI 工业化落地

🕒 10月 📍 上海 🧑 1200人

QCon

全球软件开发大会

会议时间：10月22-24日

- AI Agent
- Vibe Coding
- 智能可观测
- 推理基建
- 模型攻防
- AI x 创造力

🕒 12月 📍 北京 🧑 1000人

AiCon

全球人工智能开发与应用大会

会议时间：12月18-19日

- 大模型架构创新
- 多模态 AI 产业融合
- 具身智能
- AI for Science
- 大模型安全

AiCon

全球人工智能开发与应用大会

深圳站

探索 AI 应用边界

Explore the limits of AI applications

2026 年 8 月 21-22 日 / 深圳湾万丽酒店



参会咨询

专题: Harness Engineering: 模型之外的智能体工程

专题出品人: 柴思远

智谱 / 副总裁



专题: 超级个体与蜂群智能的共生进化

专题出品人: 张昊阳

EvoMap / 创始人



专题: AI Agent 高价值商业场景实战

专题出品人: 李响 博士

平安科技 / 智能两核 AI 部总经理



专题: 超级 App 的 AI 原生化: 端智能、端云协同与用户体验重构

专题出品人: 黎三平

京东 / 端技术负责人



专题: AI 原生新范式: Coding Agent 重构软件研发全流程

专题出品人: 林香鑫

网易游戏 / 高级技术经理



专题: 智能体时代的数据供给与治理

专题出品人: 陈廷梁 (王赟)

数新智能 / 创始人兼 CEO



05

发展曲线与展望

挡 → 围 → 盯

把今天的数据，外推成三条趋势

安全重心在 L 轴上走了一个 U 型



安全重心 U 型迁移

L1/L2 内容 → 沉到 L0/L3 基建 (今天 69%)

→ 回升到 L2 认知 / 意图 (升维)

先沉到系统底座，再回升到「Agent 的认知与意图」



防护范式三连跳

挡 (内容过滤) → 围 (边界隔离)
→ 盯 (运行时持续验证)

从静态防护走向动态治理



爆炸半径单调加速

内容 (可撤回) → 系统 (可恢复)
→ 物理/经济 (不可逆)

Cline 感染数千人 · WiFi 接管 AI 眼镜 · Meta 总监 Agent 清空邮件



从挡住它说错话
→ 围住它做错事
→ 盯住它每一个自主决策

坐标系不变，安全重心随 Agent 的自主性与连接性同步迁移



加入我们/业务交流



AI智能体应用安全测试

做什么

- Agent 产品**渗透测试**: 提示注入 / 工具劫持 / RAG投毒 / 记忆篡改
- 端侧AI终端 (AI眼镜/智能硬件) **移动安全 / IoT安全测试**
- 海内外主流AI应用**安全对标**, 输出行业对比分析
- 漏洞复现 & 论文攻击验证, 维护攻击样本集

要什么

必须 计算机/网安相关专业, 熟悉 OWASP Top 10, 有渗透经验 (CTF/SRC)

必须 了解 LLM / Agent 架构, 熟悉 Python

加分 Android逆向 / Hook / 抓包 • IoT / 嵌入式 / 硬件安全

渗透测试

Prompt Injection

RAG

OWASP

CTF/SRC



AI智能体终端助手安全测试

做什么

- 构建应用**安全画像体系**, AI编程工具开发自动化分析脚本
- 移动端AI应用 (Android / iOS) 安全分析, 端侧**Agent风险识别**
- 设计**自动化安全测试工具链**, 整合静态 + 动态分析
- 沉淀AI应用安全方法论, 风险模式 → 自动化检测规则

要什么

必须 熟悉 Android / iOS 安全, 有逆向经验 (Frida / JADX / IDA Pro)

必须 掌握 Python 或 Java/Kotlin, 了解 OWASP MASVS

必须 了解 LLM 推理 / Agent 原理, 端侧部署与端云协同认知

加分 AI辅助编程项目经验 • 攻击面管理系统 • IoT / 智能硬件安全

Android/iOS逆向

Frida

MASVS

自动化工具链

AI辅助编程

THANKS

探索 AI 应用边界

Explore the limits of AI applications

AiCon

全球人工智能开发与应用大会